Compliance Annotation

Pinnacle Health Partners, P.A.

Framework: HIPAA | Compliance Level: Non-Compliant / High Risk

---

Finding 1: [COMPLIANT] NPP Structure and Mandatory Header (45 CFR 164.520) The notice includes the mandatory verbatim header regarding the description of uses and disclosures and how to gain access. It properly identifies the Privacy Officer by name and contact information. **References:** 45 CFR 164.520(b)(1)(i), 45 CFR 164.520(b)(1)(vii)

Finding 2: [VIOLATION] Unlawful Treatment of Fundraising as "Integral" Operations (45 CFR 164.514(f)) Pinnacle classifies fundraising as an "integral component" of healthcare operations. However, the policy fails to include the mandatory statement that the individual has a right to opt out of receiving such communications, and it does not describe the mechanism for doing so. **References:** 45 CFR 164.514(f), 45 CFR 164.520(b)(1)(iii)

Finding 3: [VIOLATION] Marketing of Health-Related Products Without Authorization (45 CFR 164.508(a)(3)) The policy includes "marketing of health-related products" under general healthcare operations. Under HIPAA, any marketing communication involving financial remuneration from a third party requires a specific, signed written authorization, which is not acknowledged in this broad operations claim. **References:** 45 CFR 164.501, 45 CFR 164.508(a)(3)

Finding 4: [VIOLATION] Research Disclosures to Third-Party Commercial Partners (45 CFR 164.512(i)) The notice states that PHI may be shared with "pharmaceutical company collaborators" for clinical trials and outcomes research. This disclosure requires either an explicit patient authorization or a documented waiver from an Institutional Review Board (IRB) or Privacy Board, neither of which is mentioned in the policy. **References:** 45 CFR 164.512(i)

Finding 5: [VIOLATION] Patient Testimonials via Verbal Agreement (45 CFR 164.508) Pinnacle uses "verbal agreement" to feature recovery stories and "photographs" on social media channels. Photographs in a healthcare context constitute PHI, and their use for promotional/marketing purposes strictly requires a formal, written authorization under HIPAA. **References:** 45 CFR 164.508(a)(3)

Finding 6: [VIOLATION] Automatic HIE Participation Without Opt-Out (45 CFR 164.520) Participation in the Georgia Health Information Exchange (GaHIN) is described as "automatic for all patients". To satisfy transparency and the patient's right to request restrictions, the NPP must clearly explain how a patient can opt out of the electronic exchange, which this policy fails to provide. **References:** 45 CFR 164.520(b)(1)(iv), 45 CFR 164.522(a)

Finding 7: [VIOLATION] Breach of Minimum Necessary Standard for Research (45 CFR 164.502(b)) The policy describes broad sharing of health information with university and pharmaceutical partners without asserting the "Minimum Necessary" standard. It fails to specify the use of de-identified data or Limited Data Sets (LDS) with mandatory Data Use Agreements (DUA) for these external research disclosures. **References:** 45 CFR 164.502(b), 45 CFR 164.514(e)

Finding 8: [VIOLATION] Lack of Specificity in Breach Notification (45 CFR 164.404) While a 60-day timeline is mentioned , the policy does not describe the mandatory content of the notification, such as the types of PHI involved, the steps individuals should take to protect themselves, or a description of the entity's investigation and mitigation efforts. **References:** 45 CFR 164.404(c)